

Plan de Respuesta a Incidentes

OpenTrust Demo Services, S.L. · PLN-INC-003 · Versión 1.3

DATOS DE DEMOSTRACIÓN - ORGANIZACIÓN FICTICIA

Código	PLN-INC-003
Propietario	SOC / CISO
Versión	1.3
Fecha de aprobación	15/01/2026
Próxima revisión	15/01/2027
Clasificación	Uso interno - Demo
Controles relacionados	A.5.24, A.5.25, A.5.26, A.5.27, A.5.28

1. Organización de respuesta

Rol	Función	Contacto demo
Incident Commander	Dirigir la respuesta y decisiones	CISO
SOC	Detección, análisis y contención	soc@demo.invalid
Infraestructura	Recuperación y cambios técnicos	infra@demo.invalid
Legal / DPO	Notificación y privacidad	legal@demo.invalid
Comunicación	Mensajes internos y externos	comms@demo.invalid

2. Clasificación

Severidad	Ejemplo	Activación	Notificación interna
Crítica	Ransomware, fuga masiva, caída total	Inmediata	Dirección ≤ 30 min
Alta	Cuenta privilegiada comprometida	≤ 15 min	CISO ≤ 1 h
Media	Malware contenido, exposición limitada	≤ 1 h	Responsable ≤ 4 h
Baja	Evento sin impacto confirmado	Jornada laboral	Informe semanal

3. Proceso operativo

1. Registrar origen, hora, activos, usuario y descripción.
2. Clasificar severidad e impacto potencial.
3. Preservar evidencias: logs, memoria, correos, imágenes y hashes.
4. Contener sin destruir evidencia: aislamiento EDR, bloqueo de identidad o reglas WAF.
5. Erradicar causa raíz y validar la corrección.
6. Recuperar servicios según RTO/RPO y monitorizar recurrencia.
7. Evaluar notificaciones contractuales y regulatorias.
8. Celebrar revisión postincidente y abrir acciones.

4. Escenario demo: exposición accidental de documento

Hora	Actividad	Responsable	Resultado
08/07 10:12	Alerta de enlace público en SharePoint	Defender / SOC	Caso abierto
08/07 10:20	Revocación del enlace y sesiones	IT	Contención
08/07 10:45	Revisión de accesos y logs	SOC	12 accesos, todos internos
08/07 12:00	Evaluación de datos personales	DPO	Impacto bajo

09/07 09:30	Regla preventiva y formación	CISO	Acción correctiva
-------------	------------------------------	------	-------------------

5. Cadena de custodia

Cada evidencia recibe identificador, fecha/hora, origen, custodio, hash SHA-256 y registro de transferencias. Los originales se conservan en un contenedor inmutable de Azure Blob.

6. Simulacros

Fecha	Escenario	Resultado	Mejoras
12/06/2026	Ransomware en endpoint	RTO 2 h 15 min	Automatizar aislamiento
22/03/2026	Compromiso de identidad	Contención 18 min	Mejorar guion de comunicación